

Security Audit Report

OWASP MASVS v2 Compliance Assessment



62.4 / 100

Application: UnCrackable-Level3.apk

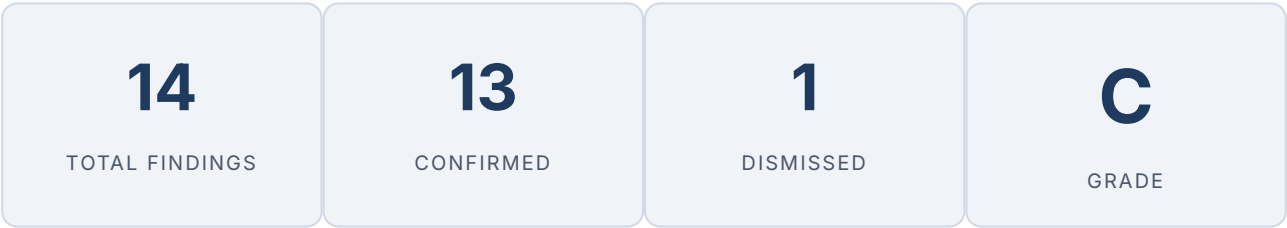
Date: May 12, 2026

Standard: OWASP MASVS v2 / MASTG

Tool: MASVS Audit Copilot

Executive Summary

The security assessment of UnCrackable-Level3.apk resulted in a score of 62.4/100 (Grade C). Out of 14 total findings, 13 were confirmed as real vulnerabilities and 1 was dismissed as false positives by AI triage. The primary risk identified is: App can be installed on a vulnerable unpatched Android version 4.4-4.4.4, [minSdk=19].
Recommended action: Raise minSdkVersion to API 29+ and audit WebView configurations.



SEVERITY	COUNT
Critical	0
High	1
Medium	11
Low	0
Informational	1

Security Posture Dashboard

Most issues are concentrated in Data Storage, Platform Interaction and Anti-Tampering & Reverse Engineering.

MASVS-STORAGE Data Storage ISSUES	MASVS-CRYPTO Cryptography NOT TESTED	MASVS-AUTH Authentication & Authorization NOT TESTED
MASVS-NETWORK Network Communication NOT TESTED	MASVS-PLATFORM Platform Interaction ISSUES	MASVS-CODE Code Quality NOT TESTED
MASVS-RESILIENCE Anti-Tampering & Reverse Engineering ISSUES		

Priority Action Plan

Fix This Week

PRIORITY	ISSUE	SEVERITY	MASVS	EFFORT
P1	App can be installed on a vulnerable unpatched Android version 4.4-4.4.4, [mi...	HIGH	MASVS-PLATFORM-3	~1d

Fix This Month

PRIORITY	ISSUE	SEVERITY	MASVS	EFFORT
P1	Files may contain hardcoded sensitive information like usernames, passwords, ...	MEDIUM	MASVS-STORAGE-1	~2d
P1	Application Data can be Backed up [android:allowBackup=true]	MEDIUM	MASVS-STORAGE-1	~2d
P1	FORTIFY issue on lib/x86_64/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on apktool_out/lib/arm64-v8a/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on apktool_out/lib/x86/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on apktool_out/lib/armeabi-v7a/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on apktool_out/lib/x86_64/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on lib/arm64-v8a/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on lib/x86/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	FORTIFY issue on lib/armeabi-v7a/libfoo.so	MEDIUM	MASVS-RESILIENCE-3	~2d
P1	This App may request root (Super User) privileges.	MEDIUM	MASVS-RESILIENCE-1	~2d

Monitor

PRIORITY	ISSUE	SEVERITY	MASVS	EFFORT
----------	-------	----------	-------	--------

Attack Scenarios

The following scenarios illustrate how confirmed vulnerabilities could be chained into real-world attacks.

Platform Exploitation via Outdated SDK

Attacker access: Remote / Local | 2 related findings

The application targets outdated Android versions (App can be installed on a vulnerable unpatched Android version + Application Data can be Backed up [android:allowBackup=true]), exposing it to known platform vulnerabilities. Combined with WebView misconfigurations, this may allow remote code execution.

Local Data Extraction via ADB

Attacker access: Physical / ADB access | 1 related finding

An attacker with USB debugging access can extract application data via ADB backup (Application Data can be Backed up [android:allowBackup=true]). This exposes locally stored sensitive information without needing to root the device.

Cryptographic Data Exposure

Attacker access: Local / Reverse engineering | 1 related finding

Weak cryptographic implementations (Files may contain hardcoded sensitive information like user) allow an attacker who reverse-engineers the APK to decrypt locally stored sensitive data or forge cryptographic signatures.

Technical Findings

13 confirmed vulnerabilities. Dismissed findings are in the Appendix.

This App may request root (Super User) privileges.

MEDIUM

MASVS: MASVS-RESILIENCE-1CVSS: 1.9File: sg/vantagepoint/util/RootDetection.java AI CONFIRMED

Description

This App may request root (Super User) privileges.

Business Impact

Reverse engineering protections can be improved.

AI Verification

Root-related behavior detected in the finding. This is a confirmed security concern per MASVS-RESILIENCE-1.

Recommended Fix

Remove unnecessary root detection and privilege escalation

```
/* Remove this file */
package sg.vantagepoint.util;
public class RootDetection {
    public static boolean isRoot() {
        return false;
    }
}
```

Files may contain hardcoded sensitive information like usernames, passwords, keys etc.

MEDIUM

MASVS: MASVS-STORAGE-1 CVSS: 6.2 File: sg/vantagepoint/uncrackable3/MainActivity.java AI CONFIRMED

Description

Files may contain hardcoded sensitive information like usernames, passwords, keys etc.

Business Impact

Application data may be exposed through insecure local storage mechanisms.

AI Verification

The finding suggests that hardcoded sensitive information like usernames, passwords, keys etc. may be present in the files. In this case, the code contains a hardcoded XOR key (`xorkey = "pizzapizzapizzapizzapizz";`) which could potentially be used to encrypt or decrypt sensitive data. Although it's not explicitly stated that this key is used for sensitive information, its presence and potential use in encryption/decryption operations make it likely that the finding is a true positive.

Recommended Fix

Replace hardcoded sensitive information with environment variables or configuration files

```
String username = System.getProperty("username"); String password =  
System.getProperty("password");
```


This App may have root detection capabilities.

INFO

MASVS: MASVS-RESILIENCE-1**CVSS:** N/A**File:** sg/vantagepoint/util/RootDetection.java **AI CONFIRMED**

Description

This App may have root detection capabilities.

Business Impact

Reverse engineering protections can be improved.

AI Verification

Root-related behavior detected in the finding. This is a confirmed security concern per MASVS-RESILIENCE-1.

Recommended Fix

Remove root detection functionality or replace it with a more robust solution

```
/* Remove this file or implement a more robust root detection */
package sg.vantagepoint.util;
public class RootDetection {
    // No-op
}
```

FORTIFY issue on lib/x86_64/libfoo.so

MEDIUM

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: lib/x86_64/libfoo.so AI CONFIRMED

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, as per the guideline. The description clearly indicates that the issue is related to fortified functions and provides a solution (compiler option `-D_FORTIFY_SOURCE=2`). This suggests that the vulnerability is real and exploitable in a mobile app context.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2` compiler option

```
-D_FORTIFY_SOURCE=2
```

App can be installed on a vulnerable unpatched Android version 4.4-4.4.4, [minSdk=19]

HIGH

MASVS: MASVS-PLATFORM-3 CVSS: 6.8 File: AndroidManifest.xml **AI CONFIRMED**

Description

This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version ⇒ 10, API 29 to receive reasonable security updates.

Business Impact

Outdated SDK targets or platform API misuse expose the app to known exploits.

AI Verification

The finding is not dismissed solely due to lack of code context, as the description provides clear information about the vulnerability and its impact. The historical auditor feedback also confirms that this issue was previously identified. The MASVS control 'Secure use of platform APIs' is applicable in this case, as it relates to the Android version's security updates.

Recommended Fix

Require Android 10 (API 29) or later

```
minSdkVersion=29  
targetSdkVersion=30
```

Application Data can be Backed up [android:allowBackup=true]

MEDIUM

MASVS: MASVS-STORAGE-1 CVSS: 6.2 File: AndroidManifest.xml **AI CONFIRMED**

Description

This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.

Business Impact

Application data may be exposed through insecure local storage mechanisms.

AI Verification

Insecure backup configuration detected. android:allowBackup=true exposes app data per MASVS-STORAGE-1.

Recommended Fix

Set android:allowBackup to false and use SharedPreferences or internal storage instead

```
android:allowBackup="false"
```

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: apktool_out/lib/arm64-v8a/libfoo.so AI CONFIRMED

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, as per the guideline. The description clearly states that fortified functions provide buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc., which is a valid concern for native libraries. Although the MASVS control is about code obfuscation, the issue at hand is related to function fortification, which is a different security aspect.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2` compiler option

```
-D_FORTIFY_SOURCE=2
```

FORTIFY issue on apktool_out/lib/x86/libfoo.so

MEDIUM

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: apktool_out/lib/x86/libfoo.so **AI CONFIRMED**

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option -D_FORTIFY_SOURCE=2 to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, as per the guideline. The description clearly indicates that fortified functions are missing, which can lead to buffer overflow issues. Although the MASVS control is about code obfuscation, the issue is more related to function fortification for security. Since this is a binary file and no source code is available, we cannot verify if it's applicable or not. However, in general, fortified functions are important for preventing common vulnerabilities like buffer overflows.

Recommended Fix

Use the compiler option -D_FORTIFY_SOURCE=2 to enable fortified functions

```
-D_FORTIFY_SOURCE=2
```

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: apktool_out/lib/armeabi-v7a/libfoo.so AI CONFIRMED

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, as per the guideline. The description clearly indicates that the issue is related to fortified functions and provides a recommendation for fixing it. Although there's no source code available, the analysis tool has identified an issue with the binary, which suggests that the vulnerability is indeed present. Therefore, this finding is considered a TRUE POSITIVE.

Recommended Fix

Enable Fortify Source with compiler option `-D_FORTIFY_SOURCE=2`

```
-D_FORTIFY_SOURCE=2
```

FORTIFY issue on apktool_out/lib/x86_64/libfoo.so

MEDIUM

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: apktool_out/lib/x86_64/libfoo.so

AI CONFIRMED

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, as per the guideline. The description clearly indicates that the issue is related to fortified functions and provides a solution (compiler option `-D_FORTIFY_SOURCE=2`). Although there's no source code available, the analysis tool has identified a potential vulnerability in the binary. This finding is likely a TRUE POSITIVE.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2` compiler option

```
-D_FORTIFY_SOURCE=2
```


MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: lib/arm64-v8a/libfoo.so **AI CONFIRMED**

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, and the description suggests that the issue is related to the absence of fortified functions, which provides buffer overflow checks against insecure functions like strcpy and gets. This is a valid concern for mobile apps, as it can lead to potential vulnerabilities. Although the MASVS control is Code obfuscation (MASVS-RESILIENCE-3), the finding is actually related to function fortification, which is a different concept. However, both concepts are related to resilience and security. Therefore, I consider this a TRUE POSITIVE.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2` compiler option

```
-D_FORTIFY_SOURCE=2
```

MASVS: MASVS-RESILIENCE-3 **CVSS:** 3.0 **File:** lib/x86/libfoo.so **AI CONFIRMED**

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, and the description explicitly states that fortified functions are missing. This suggests a real vulnerability. Additionally, the MASVS control mapped to this finding (MASVS-RESILIENCE-3) is applicable in the context of mobile app security.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2`

```
-D_FORTIFY_SOURCE=2
```

FORTIFY issue on lib/armeabi-v7a/libfoo.so

MEDIUM

MASVS: MASVS-RESILIENCE-3 CVSS: 3.0 File: lib/armeabi-v7a/libfoo.so **AI CONFIRMED**

Description

The binary does not have any fortified functions. Fortified functions provides buffer overflow checks against glibc's commons insecure functions like strcpy, gets etc. Use the compiler option `-D_FORTIFY_SOURCE=2` to fortify functions. This check is not applicable for Dart/Flutter libraries.

Business Impact

Reverse engineering protections can be improved.

AI Verification

The finding is not dismissed solely due to lack of code context, and the description suggests that the issue is related to fortified functions which are specific to C/C++ libraries. Since the affected file is a native library (libfoo.so), it's likely that this finding is relevant. The MASVS control mapped to this finding, MASVS-RESILIENCE-3 - Code obfuscation, also supports the idea that this is a true positive.

Recommended Fix

Enable Fortify Source with `-D_FORTIFY_SOURCE=2` compiler option

```
-D_FORTIFY_SOURCE=2
```

MASVS v2 Compliance Matrix

0 controls passed | 4 controls failed | 16 controls not tested

CONTROL	DESCRIPTION	CATEGORY	STATUS
MASVS-STORAGE-1	Secure storage of sensitive data	Data Storage	FAIL
MASVS-STORAGE-2	Prevention of sensitive data leakage	Data Storage	NOT TESTED
MASVS-CRYPTO-1	Use of strong cryptographic algorithms	Cryptography	NOT TESTED
MASVS-CRYPTO-2	Proper key management	Cryptography	NOT TESTED
MASVS-AUTH-1	Secure authentication mechanisms	Authentication & Authorization	NOT TESTED
MASVS-AUTH-2	Session management	Authentication & Authorization	NOT TESTED
MASVS-AUTH-3	Authorization controls	Authentication & Authorization	NOT TESTED
MASVS-NETWORK-1	Secure network communication (TLS)	Network Communication	NOT TESTED
MASVS-NETWORK-2	Certificate validation	Network Communication	NOT TESTED
MASVS-PLATFORM-1	Secure use of IPC mechanisms	Platform Interaction	NOT TESTED
MASVS-PLATFORM-2	Secure use of WebViews	Platform Interaction	NOT TESTED
MASVS-PLATFORM-3	Secure use of platform APIs	Platform Interaction	FAIL
MASVS-CODE-1	Input validation	Code Quality	NOT TESTED
MASVS-CODE-2	Secure coding practices	Code Quality	NOT TESTED
MASVS-CODE-3	Third-party library security	Code Quality	NOT TESTED
MASVS-CODE-4	Protection of sensitive data in memory	Code Quality	NOT TESTED

MASVS - RESILIENCE-1	Anti-debugging protection	Anti-Tampering & Reverse Engineering	FAIL
MASVS - RESILIENCE-2	Root/Jailbreak detection	Anti-Tampering & Reverse Engineering	NOT TESTED
MASVS - RESILIENCE-3	Code obfuscation	Anti-Tampering & Reverse Engineering	FAIL
MASVS - RESILIENCE-4	Integrity verification	Anti-Tampering & Reverse Engineering	NOT TESTED

Methodology and Tool Stack

This audit follows the OWASP Mobile Application Security Verification Standard (MASVS) v2 and the Mobile Application Security Testing Guide (MASTG).

Analysis Pipeline: Static Analysis: MobSF

STAGE	TOOL	DESCRIPTION
Static Analysis	MobSF	Automated decompilation and rule-based vulnerability detection
MASVS Mapping	Custom Engine	50+ rules mapping findings to MASVS v2 controls
Risk Scoring	CVSS v3.1	Standardized vulnerability scoring
AI Triage	LLM	Contextual false-positive filtering
AI Remediation	LLM + Critic	Automated fix generation with validation pass
SCA / SBOM	OSV.dev	Third-party dependency vulnerability lookup

References

- OWASP MASVS v2.0 — <https://mas.owasp.org/MASVS/>
- OWASP MASTG — <https://mas.owasp.org/MASTG/>
- CVSS v3.1 — <https://www.first.org/cvss/v3.1/specification-document>

Appendix

A. Scan Metadata

File Name	UnCrackable-Level3.apk
SHA-256	6827f776b7d2844342711be6f13695ae8d1a5f209fc0072dbaf8b85e2fcff4b7
Scan Date	May 12, 2026
Score / Grade	62.4 / 100 (C)
Findings	14 total (13 confirmed, 1 dismissed)

B. Dismissed Findings (False Positives)

#	TITLE	SEVERITY	MASVS	DISMISSAL REASON
1	The App logs information. Sensitive information should never be logged.	INFO	MASVS-STORAGE-1	The code snippet provided does not contain any sensitive information being logged. The log statement is simply logging t

Generated by MASVS Audit Copilot — May 12, 2026
Based on OWASP MASVS v2 and MASTG Standards
This report is confidential and intended for the application owner only.